Studentessa	Corso	Attività svolta
Martina Foresta	Cybersecurity	Null Session e MITM con Ettercap

Analisi di Null Session e simulazione MITM con Ettercap

1. Obiettivo e perimetro dell’attività

L’esercizio è composto da una parte teorica su Null Session e ARP Poisoning e da una prova pratica di tipo Man-in-the-Middle. La simulazione è stata eseguita con macchine virtuali collegate alla rete 192.168.50.0/24.

La prova pratica aveva lo scopo di verificare se, inserendo Kali tra un computer Windows e il gateway, fosse possibile osservare il traffico HTTP non cifrato.

2. Null Session

2.1 Significato

Una Null Session è una connessione ai servizi di condivisione Windows effettuata senza fornire credenziali valide, cioè con identità vuota o anonima. Sui sistemi e sulle configurazioni più vecchie può permettere di enumerare informazioni come nomi di utenti, gruppi, condivisioni e risorse esposte. Non significa però ottenere automaticamente le password degli utenti.

2.2 Sistemi interessati e stato commerciale

Nella traccia sono indicati Windows NT, Windows 2000, Windows XP e Windows Server 2003. Sono sistemi legacy che non sono più prodotti supportati o commercializzati come piattaforme correnti. Installazioni esistenti possono ancora funzionare, ma non ricevono il normale supporto e gli aggiornamenti di sicurezza: Microsoft raccomanda la migrazione a versioni supportate. Le versioni moderne di Windows hanno impostazioni predefinite più restrittive, anche se configurazioni errate o servizi legacy possono ancora esporre accessi anonimi.

2.3 Mitigazione della Null Session

1. Disabilitare condivisione di file e stampanti quando non necessaria. È efficace perché elimina il servizio esposto, ma può avere un impatto elevato nelle aziende che usano condivisioni di rete.

2. Disabilitare NetBIOS su TCP/IP se non richiesto. Riduce i servizi legacy disponibili; l'effort è medio perché occorre verificare la compatibilità delle applicazioni.

3. Filtrare il traffico con firewall e monitorare la rete. Limita le connessioni non autorizzate; per l'utente l'impatto è basso, mentre l'azienda deve configurare e controllare le regole.

4. Disabilitare l'account Guest. È una misura semplice, con effort basso e senza effetti sugli utenti autorizzati.

5. Aggiornare o sostituire i sistemi obsoleti. Installare patch disponibili richiede effort contenuto; migrare a una versione moderna può richiedere costi, test, nuova configurazione e talvolta hardware compatibile.

6. Limitare i permessi delle condivisioni ai soli utenti necessari e usare strumenti di sicurezza. È una buona pratica continua; richiede gestione delle autorizzazioni e monitoraggio periodico.

3. ARP Poisoning

3.1 Come funziona

ARP associa un indirizzo IPv4 a un indirizzo MAC nella rete locale. Nell'ARP Poisoning l'attaccante invia risposte ARP false ai due estremi della comunicazione: alla vittima dichiara di possedere l'indirizzo del gateway e al gateway dichiara di possedere l'indirizzo della vittima. Le tabelle ARP vengono quindi aggiornate con il MAC dell'attaccante e il traffico può attraversare la sua macchina.

3.2 Sistemi vulnerabili

Sono esposti i dispositivi che appartengono allo stesso dominio di broadcast di livello 2 e usano ARP senza autenticazione. Il rischio non dipende da uno specifico sistema operativo: può riguardare computer, server, macchine virtuali e apparati di rete presenti nella stessa LAN.

3.3 Mitigazione e rilevamento

1. HTTPS/TLS e VPN cifrano i dati in transito. Non impediscono da soli l'ARP Poisoning, ma evitano che chi intercetta il traffico possa leggere facilmente il contenuto.

2. Segmentazione e switch di livello 3 riducono l'ampiezza del dominio di broadcast. Sono efficaci nelle reti aziendali, ma richiedono progettazione, configurazione e apparati adeguati.

3. Monitoraggio costante consente di individuare cambi improvvisi nelle associazioni IP-MAC e risposte ARP anomale. La traccia cita Arpwatch, XArp e l'IDS Snort.

4. Software di sicurezza aggiornato e formazione degli utenti completano la difesa. La formazione riduce soprattutto il rischio di usare servizi HTTP non cifrati o di ignorare gli avvisi del browser.

4. Ambiente di laboratorio

• Kali Linux: macchina di test, 192.168.50.100, interfaccia eth0, MAC 08:00:27:94:C1:4E.

• Windows 10: macchina vittima, 192.168.50.102, MAC 08:00:27:9F:43:7C.

• Gateway pfSense: 192.168.50.1, MAC 08:00:27:2B:95:C6.

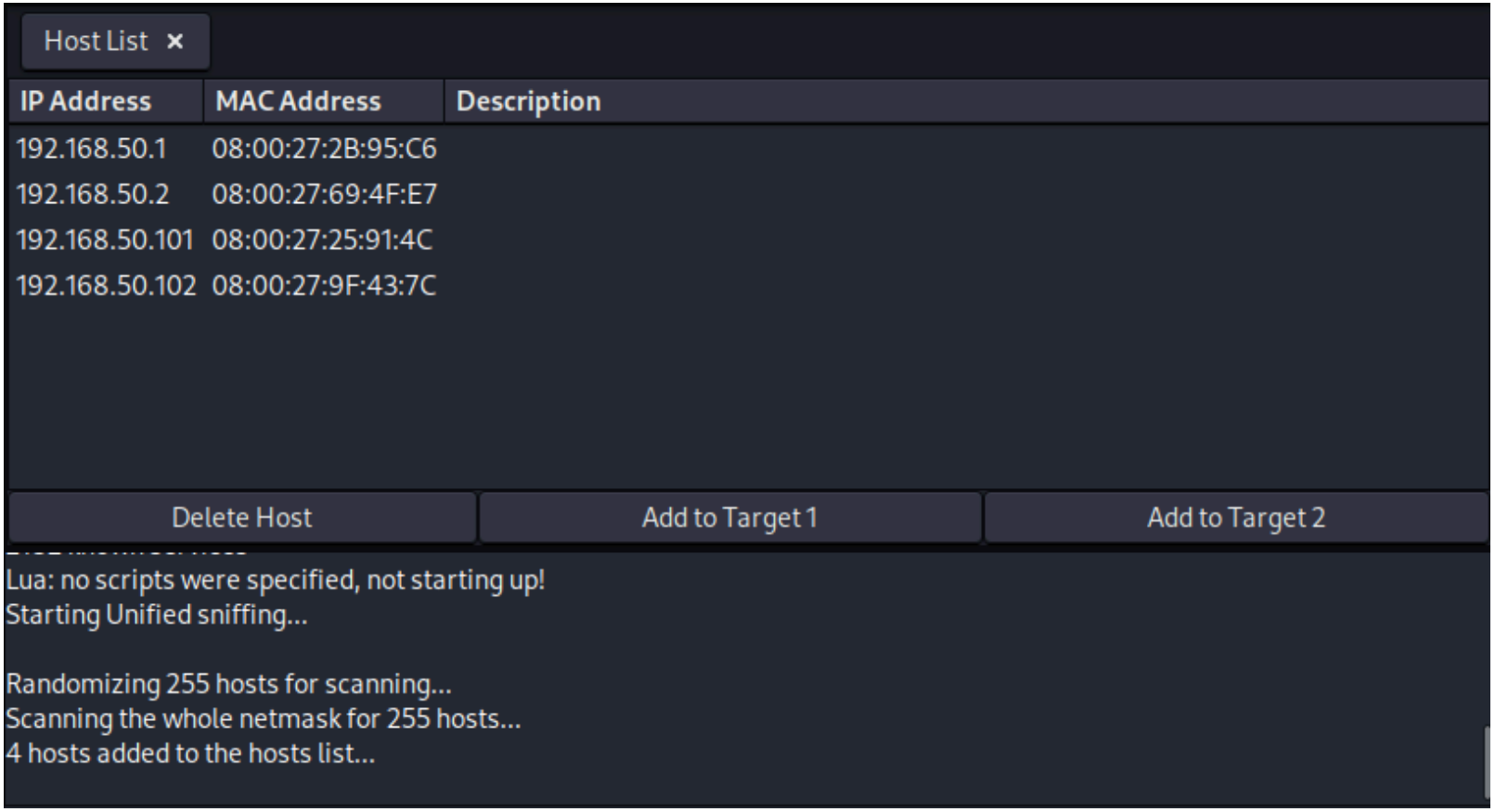
• Host 192.168.50.2 e Metasploitable 192.168.50.101: rilevati durante la scansione, ma non selezionati come target della prova finale.

4.1 Avvio di Ettercap e scansione degli host

Ettercap 0.8.4.1 è stato avviato in modalità grafica con Unified Sniffing sull'interfaccia eth0. Dal menu Hosts è stata avviata la scansione dell'intera rete /24.



La scansione ha restituito quattro host: 192.168.50.1, 192.168.50.2, 192.168.50.101 e 192.168.50.102.

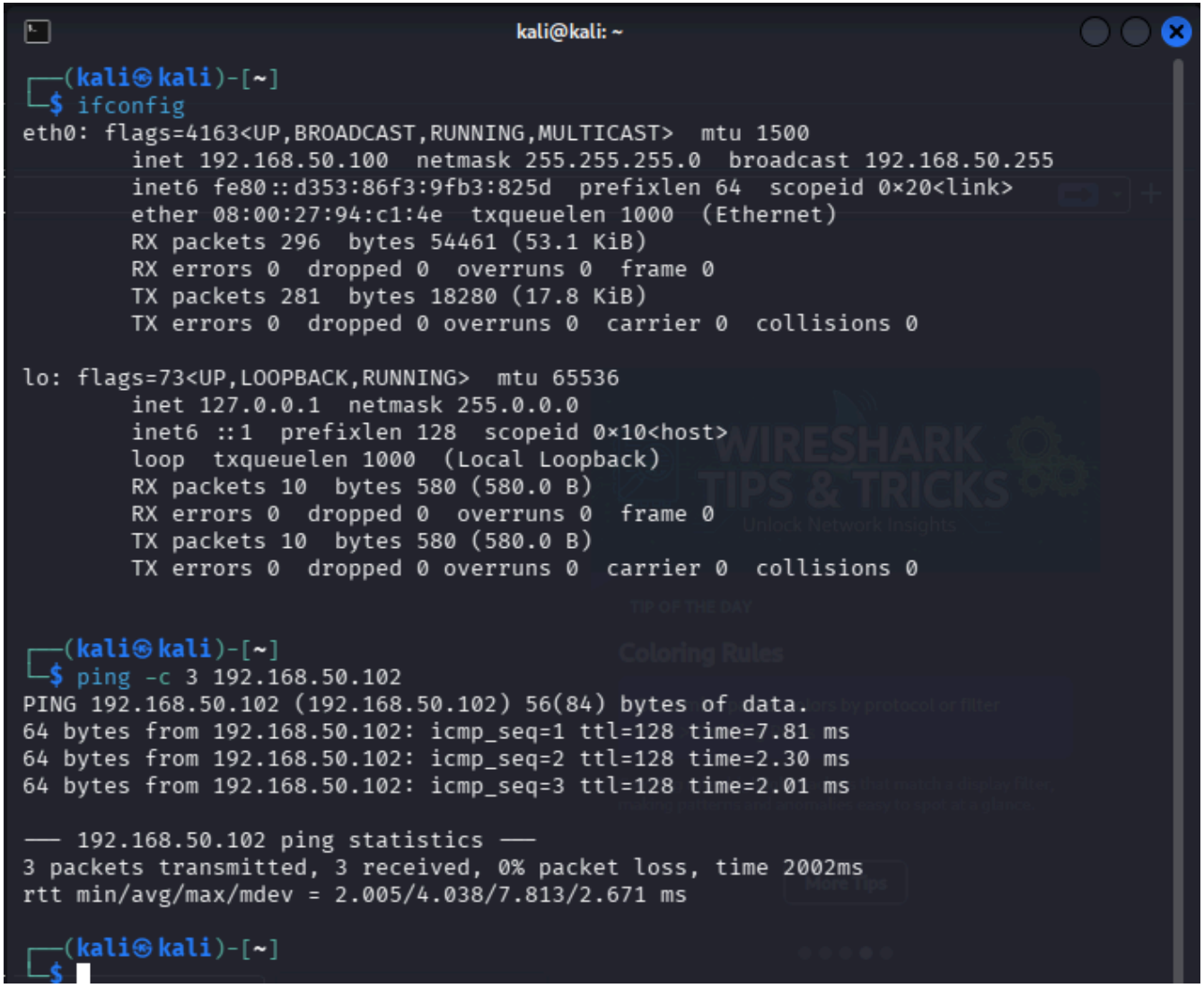


4.2 Identificazione della macchina Windows

```
ifconfig
```

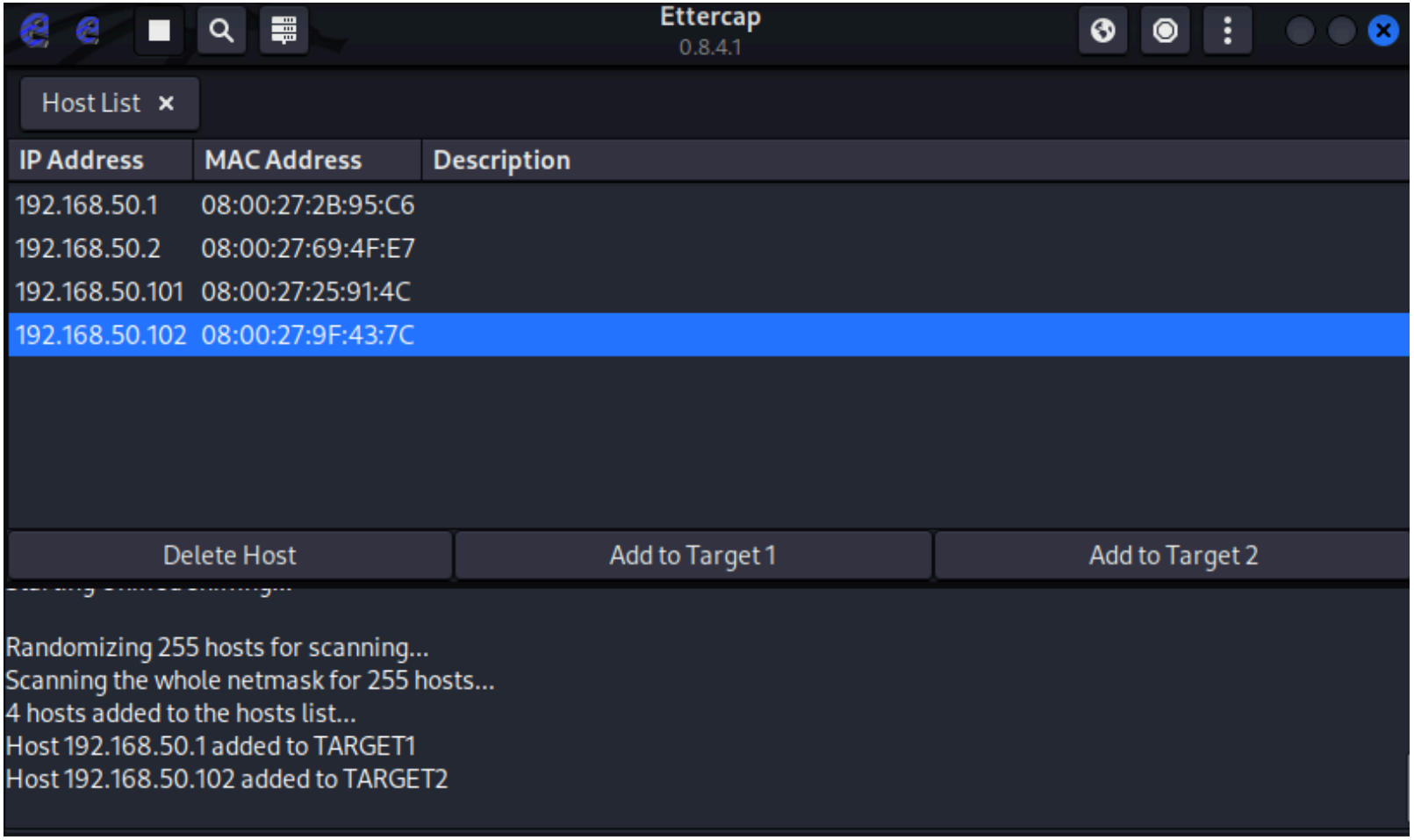
```
ping -c 3 192.168.50.102
```

ifconfig ha confermato l'indirizzo 192.168.50.100 su eth0. Il ping verso 192.168.50.102 ha ricevuto tre risposte su tre, senza perdita di pacchetti; il TTL 128 è coerente con la macchina Windows accesa per la prova.



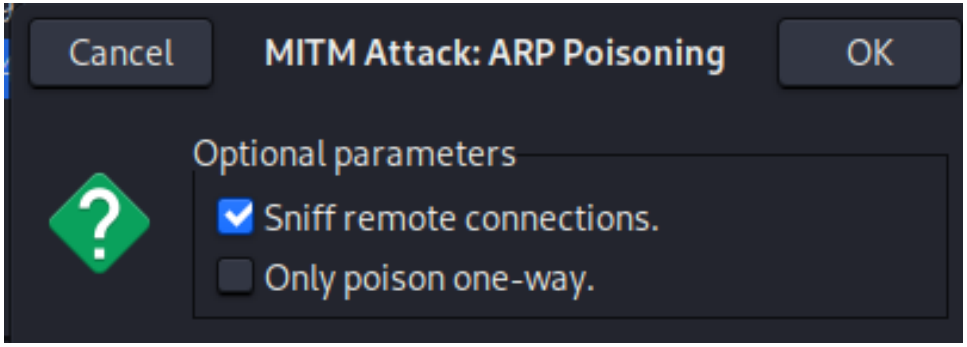
4.3 Selezione dei target

In Ettercap il gateway 192.168.50.1 è stato aggiunto a TARGET1 e Windows 192.168.50.102 a TARGET2. Gli altri host rilevati non sono stati inseriti nei gruppi dell’attacco.

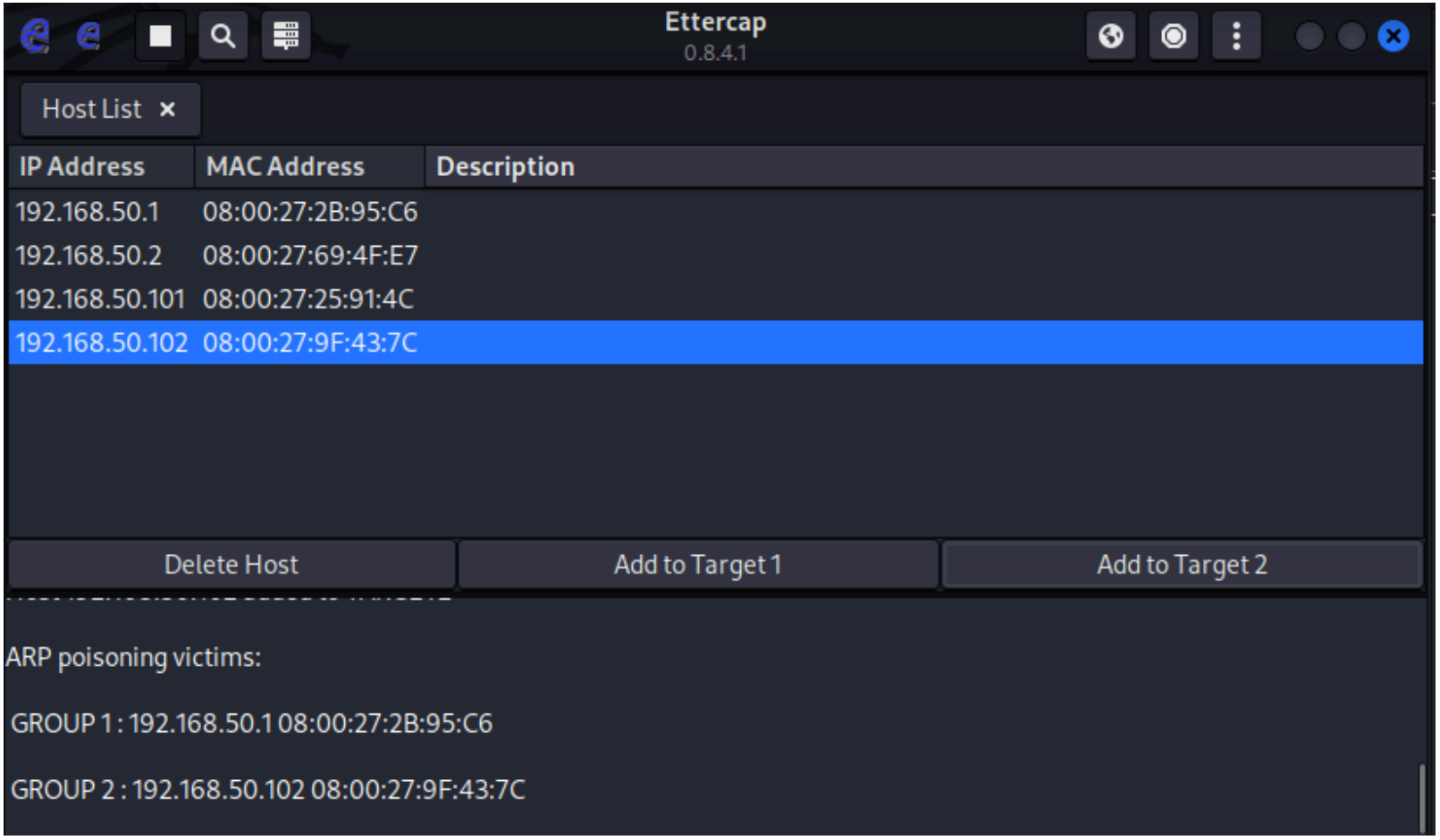


5. Configurazione e avvio dell’ARP Poisoning

Dal menu MITM è stato selezionato ARP Poisoning. L’opzione “Sniff remote connections” è rimasta attiva, mentre “Only poison one-way” è rimasta disattivata, così da inviare le associazioni false in entrambe le direzioni.

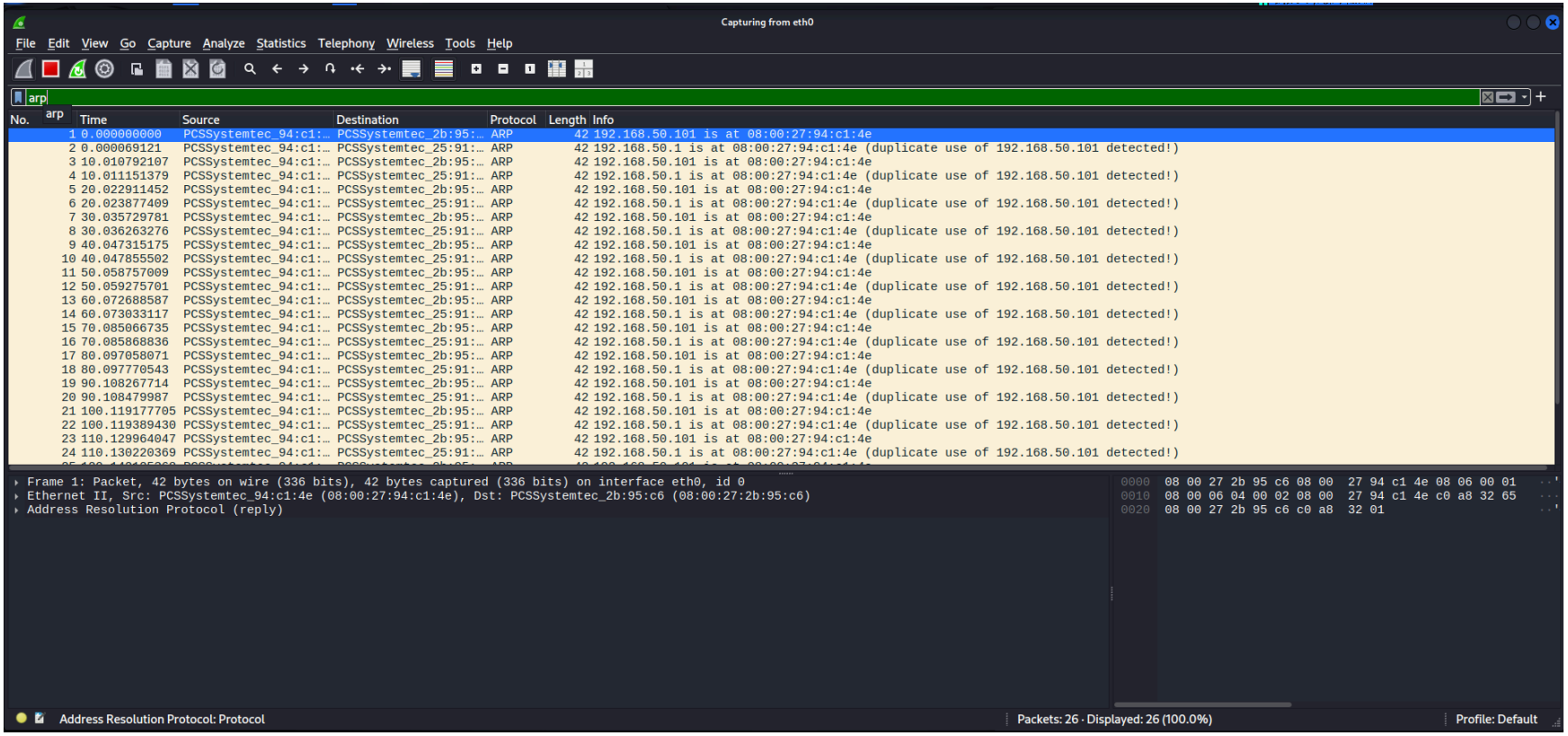


Dopo la conferma, Ettercap ha mostrato le due vittime dell’avvelenamento: GROUP 1 con 192.168.50.1 e GROUP 2 con 192.168.50.102.



6. Verifica dei pacchetti ARP con Wireshark

Wireshark è stato avviato su eth0 e il filtro arp ha isolato le risposte ARP. La cattura mostra ripetutamente due informazioni false: 192.168.50.102 associato al MAC di Kali 08:00:27:94:C1:4E e 192.168.50.1 associato allo stesso MAC. L'avviso "duplicate use" evidenzia l'incoerenza generata dalle associazioni duplicate.

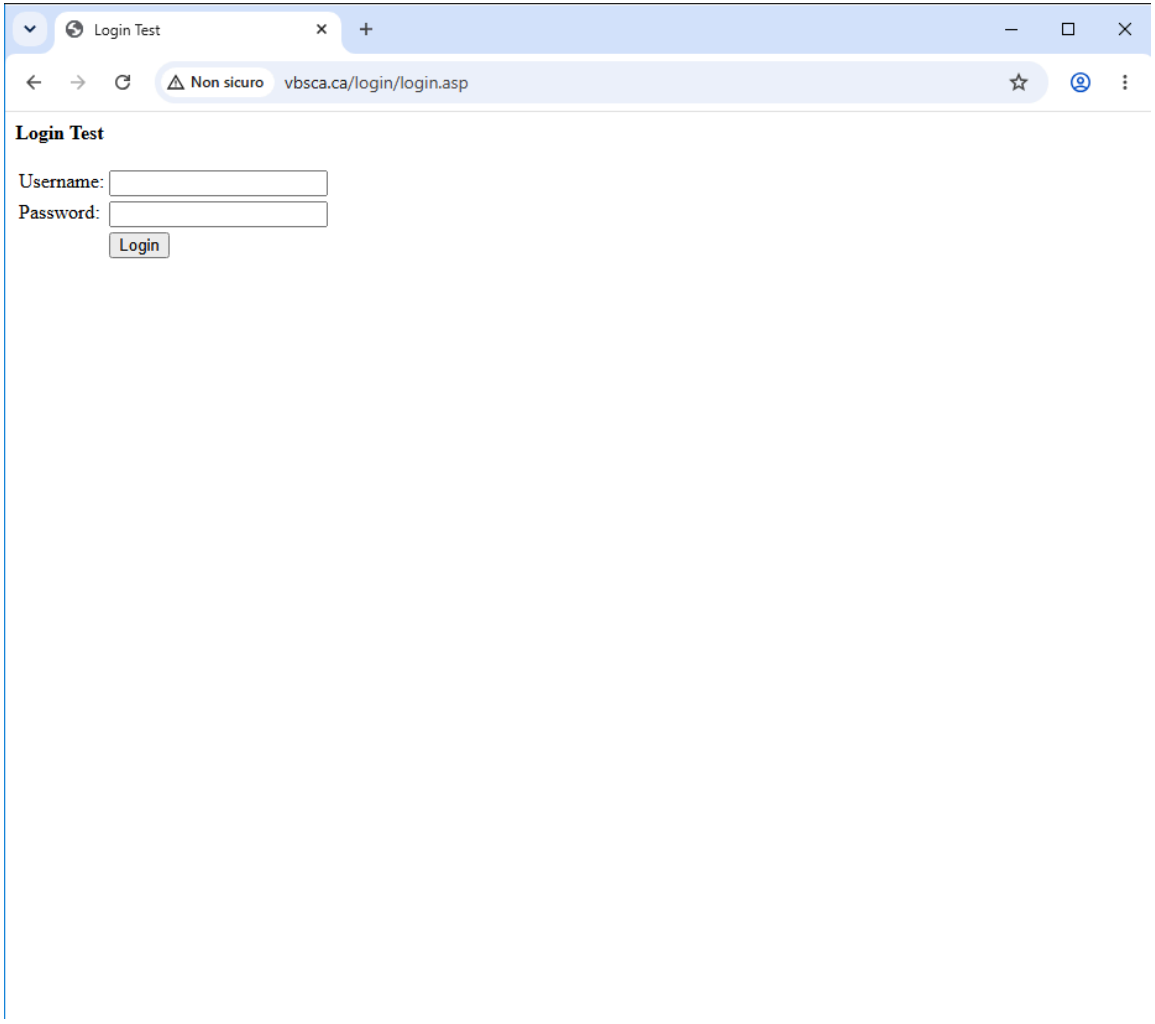


7. Test HTTP e intercettazione del POST

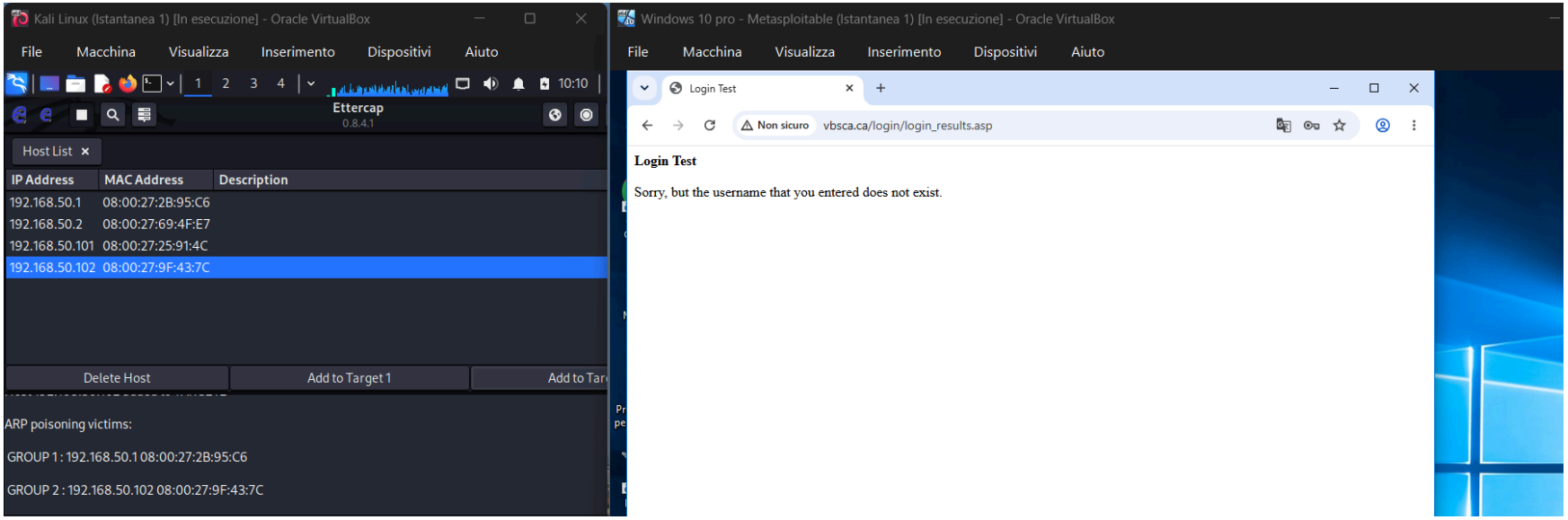
Sul browser della macchina Windows è stato aperto il sito indicato nella traccia aggiornata:

http://vbsca.ca/login/login.asp

Il browser lo ha segnalato come “Non sicuro” perché la pagina utilizzava HTTP e non HTTPS. Nel modulo sono stati inseriti esclusivamente i dati fittizi mario e rossi.



La prova è stata eseguita mentre Ettercap manteneva attivo l’ARP Poisoning tra il gateway e Windows.

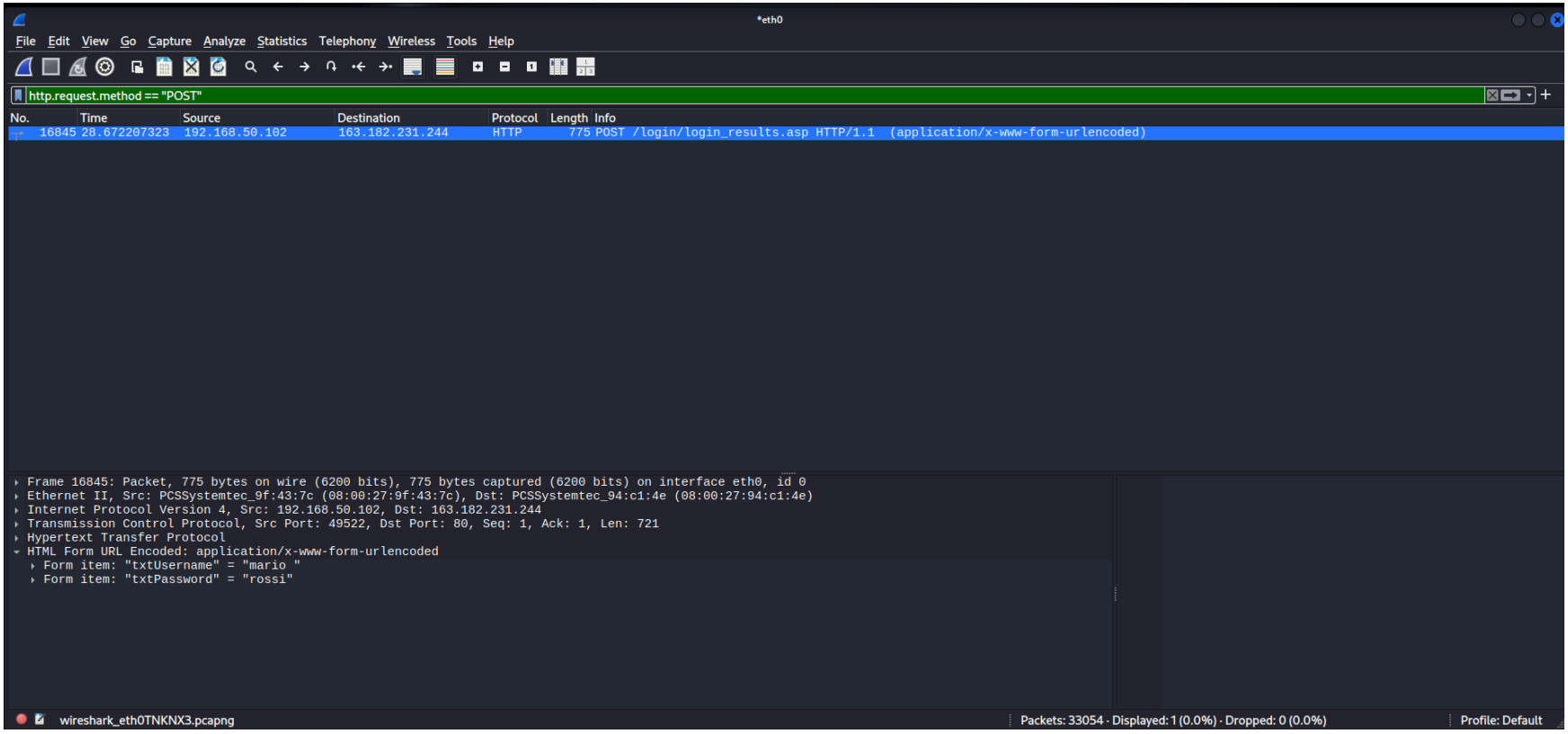


La pagina di risposta ha indicato che il nome utente non esisteva. Il login, quindi, non è riuscito; ciò era previsto perché i dati erano stati scelti soltanto per dimostrare il transito del modulo.

In Wireshark è stato applicato il filtro:

http.request.method == "POST"

È stato visualizzato un unico pacchetto POST proveniente da 192.168.50.102 e diretto a 163.182.231.244 sulla porta 80, con richiesta POST /login/login_results.asp HTTP/1.1. Espandendo “HTML Form URL Encoded” risultavano leggibili i campi txtUsername = “mario” e txtPassword = “rossi”. Questa è la prova verificata che il contenuto del modulo HTTP è transitato senza cifratura ed è stato osservato da Kali.



8. Conclusioni

L’esercitazione ha mostrato il meccanismo dell’ARP Poisoning e la sua conseguenza principale: un host nella stessa LAN può tentare di inserirsi tra vittima e gateway. La cattura del POST dimostra inoltre perché le credenziali non devono essere inviate tramite HTTP. HTTPS/TLS avrebbe cifrato il contenuto applicativo, rendendo i campi del modulo non leggibili in chiaro anche in presenza di traffico intercettato.